

Introduction

What GiftKeeper does

GiftKeeper is a Flutter application mainly designed for managing birthdays and gift planning. It reminds user prior to and on the day of the occasion via notifications while also keeping track of user’s relationship and notes about the person’s interests and history of gifts. It uses a feature called ‘Generate AI Suggestions’ where the model analyses the data provided (relationship, interests, notes) and suggests 10 gift ideas based on it. The app uses Hive storage to store data locally on the user’s phone which is also fast and designed for flutter/dart.

Why it Handles Personal Data

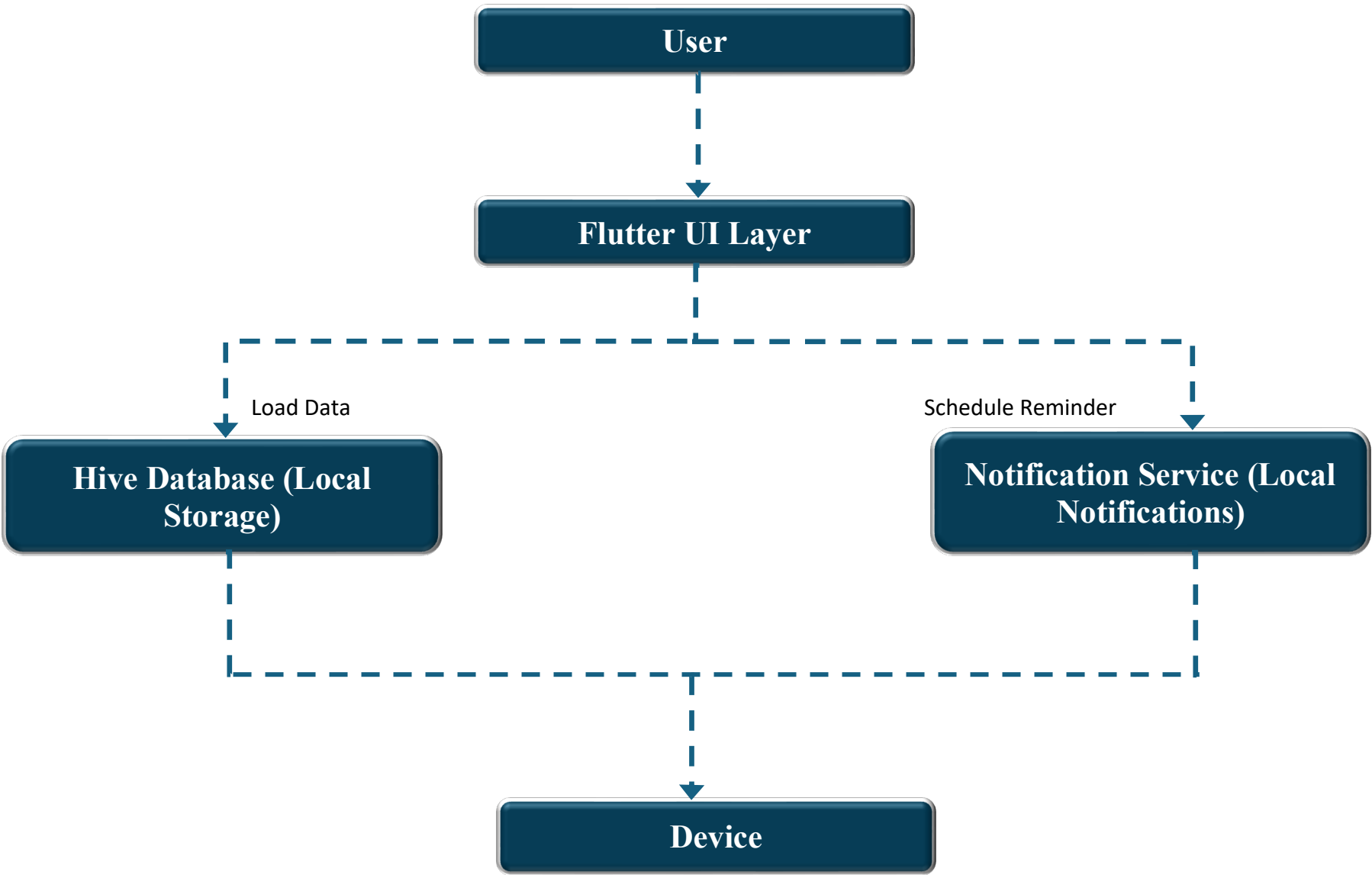
The feature that generates ideas uses an API key to access the Groq AI model. This gives it the access to personal information that the user stores about people in their real lives. To process and suggest gift ideas, the model requires info like previously gifted items which is not as personal as the other details it may use like relationship to the user, interests or miscellaneous notes that may contain private data and communications.

Purpose of the Audit

Since the application handles personal data, the purpose of this audit is to identify potential vulnerabilities in data storage, privacy, and authentication along with documenting the findings and the research for mitigation strategies.

Application Overview

Architecture Diagram



User –

The user interacts with the application by editing birthdays (or other occasions), recording gift ideas, and viewing reminders.

Flutter UI –

Responsible for screens, buttons, forms, and navigation. It includes files like main.dart, home_screen.dart, person_details.dart, etc.

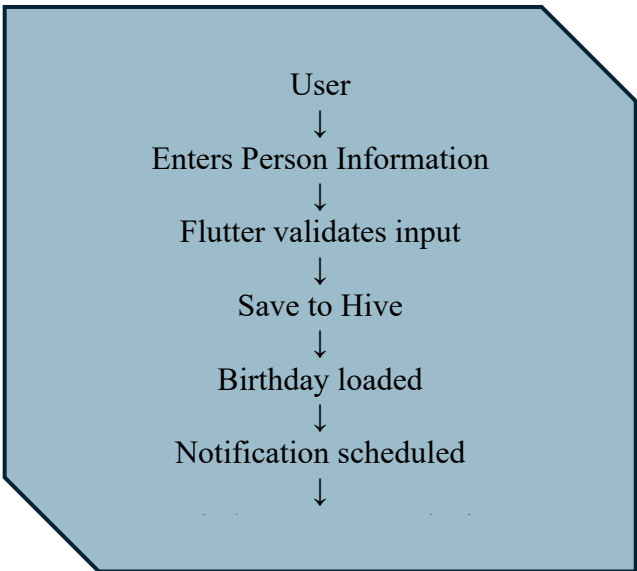
Hive Database –

All personal information is stored locally using Hive, reducing dependence on external servers.

Notification Service –

Reads birthday dates and schedules local notifications as reminders.

Data Flow Diagram



Assets

Names, Birthdays, Gift ideas, Personal notes, Notification settings

Threats

What If Someone Steals The Phone?

One of the primary threats to GiftKeeper is unauthorised access following the loss or theft of an user’s device. The app stores personal information including birthdays, gift ideas, and relationships using Hive local database and this information could be exposed. Although storing data locally reduces the risk of remote data breaches because personal information is never transmitted to external servers, an attacker with physical access to the device may be able to recover these. Another consideration is the visibility of notification content. Birthday reminders displayed on the lock screen may unintentionally reveal information to anyone.(Patsakis and Alepis, 2018)

Modern operating systems provide biometric or passcode authentication which reduces the likelihood of the threat. None the less, OWASP recommends that applications should not solely rely on device security for protection. (*Mobile Application Security - OWASP Cheat Sheet Series*, no date)

What If Malware Accesses App Storage?

While local storage offers privacy advantages by avoiding cloud transmission, it also increases risk of data exposure if malicious software gain access to the device’s stored files. If the Hive database is stored without encryption, the attacker could recover sensitive information like names, birthdays, gift ideas, relationship details and personal notes. Therefore, the absence of application-level encryption means that a compromised device may still expose locally stored information although it is less likely. (*Mobile Application Security - OWASP Cheat Sheet Series*, no date) advises developers to minimise storage of sensitive data and ensure that it is adequately protected.

What If An AI Api receives Sensitive Notes?

GiftKeeper uses an external AI service to generate personalised gift recommendations based on information entered by the user. To provide meaningful suggestions, the application may transmit details such as hobbies, interests, age group, relationship information, and gift references. While this is a feature that stands out, it changes the app’s security and privacy model because information is processed outside the user’s device. Unlike information stored locally within the Hive database, API requests involve transmitting user data across a network to a third-party service.

Although communication is protected using HTTPS, which means the information is transmitted only when the feature is invoked rather than continuously collected, developers must also consider how the external service stores and processes given information. (*Insecure API usage | Security*, no date) highlights that applications communicating with external APIs should use secure authentication methods, protect credentials, and avoid exposing sensitive information unnecessarily during API communication.

What If The API Key Is Exposed?

GiftKeeper communicates with Groq Chat Completions API to generate recommendations and this requires authentication using an API key. If this key were to be exposed through the application source code, reverse engineering, an insecure repository, or accidental publication, an unauthorised user could use the key to make requests to the API while impersonating the application. It presents financial and security risks like the attacker consuming API credits or generating unexpected costs for the developer. The Groq API documentation recommends authenticating requests using API keys and keeping those credentials secure rather than exposing them in publicly accessible code or applications. (*API Reference - GroqDocs*, no date)

Risk Assessment

Threat	Likelihood	Impact	Risk	Mitigation
Phone stolen	Medium	Medium	Medium	Device encryption

Malware accessing storage	Low	High	Medium	Encrypt local database
Sensitive data sent to AI API	High	Medium	High	Store only necessary data
Exposure of API key	Medium	Medium	Medium	Using a secure backend for storing and rotating keys regularly.

Recommendations

- Encrypt sensitive local data stored within the Hive database to protect against unauthorized access if application files are extracted from a compromised device.(*Mobile Application Security - OWASP Cheat Sheet Series*, no date)
- Apply the principle of data minimization by transmitting only the information required to generate AI-powered gift recommendations. Unnecessary personal information should remain on user’s device. (“Art. 5 GDPR – Principles relating to processing of personal data,” no date)
- Provide clear user notification before AI processing so users understand that selected information will be sent to the Groq API to generate gift suggestions. This improves transparency and supports informed consent
- Use secure API communication by ensuring all requests to the Groq Chat Completions API are transmitted over HTTPS and that API keys are stored securely (e.g., environment variables or secure backend services) rather than hard-coded into the application. (*Groq Quickstart Guide*, no date) (*API Reference - GroqDocs*, no date)
- Review third-party data handling practices before integrating AI services. Developers should understand how submitted prompts are processed and ensure users are informed of any relevant privacy implications.
- Improve notification privacy by allowing users to hide reminder content on the lock screen, reducing the possibility of exposing personal information to others. .(Patsakis and Alepis, 2018)
- Provide users with greater control over their data, including options to delete stored information and continue using the application without AI-generated recommendations. (“Art. 5 GDPR – Principles relating to processing of personal data,” no date)
- Perform periodic security reviews whenever new features or third-party integrations are introduced to ensure that the application's security posture remains appropriate.

Conclusion

This security assessment evaluated the main privacy and security risks associated with GiftKeeper, including device theft, malware accessing local storage, transmission of personal information to external AI services, and API key exposure. While GiftKeeper's local-first design reduces its exposure to some risks, the assessment identified several areas where additional security measures could improve the protection of user data.

The recommended improvements include encrypting sensitive local data, securely managing API credentials, minimising the information sent to external services, improving notification privacy, and giving users greater control over their data.

Overall, this assessment demonstrated that building a functional application is only one part of software development; considering how user data is collected, stored, transmitted, and protected is equally important. Conducting the assessment also provided an opportunity to evaluate GiftKeeper's current design critically and identify areas for improvement as the application develops further.

References

API Reference - GroqDocs (no date). Available at: https://console.groq.com/docs/api-reference?utm_source=chatgpt.com#chat-create (Accessed: August 6, 2026).

“Art. 5 GDPR – Principles relating to processing of personal data” (no date) *General Data Protection Regulation (GDPR)*. Available at: <https://gdpr-info.eu/art-5-gdpr/> (Accessed: August 5, 2026).

Insecure API usage | Security (no date) *Android Developers*. Available at: <https://developer.android.com/privacy-and-security/risks/insecure-api-usage> (Accessed: August 5, 2026).

Mobile Application Security - OWASP Cheat Sheet Series (no date). Available at: https://cheatsheetseries.owasp.org/cheatsheets/Mobile_Application_Security_Cheat_Sheet.html?utm_source=chatgpt.com (Accessed: August 4, 2026).

Patsakis, C. and Alepis, E. (2018) “Knock-Knock: The unbearable lightness of Android Notifications.” arXiv. Available at: <https://doi.org/10.48550/arXiv.1801.08225>.

Quickstart (no date) *GroqDocs*. Available at: <https://console.groq.com/docs> (Accessed: August 6, 2026).